CONFIDENCIAL — USO INTERNO

TUM2026 — Reporte Comparativo de Seguridad

Proyecto: TUM2026 IT Admin Dashboard **Auditoría 1:** 12 de marzo, 2026 **Auditoría 2:** 13 de marzo, 2026 **Clasificación:** Confidencial

1. Resumen Ejecutivo

Entre la primera auditoría (12 mar) y la segunda (13 mar), se resolvieron los **8 hallazgos críticos** identificados inicialmente. Sin embargo, la segunda auditoría más exhaustiva descubrió **3 nuevos hallazgos críticos** que siguen el mismo patrón: el equipo corrigió las rutas de escritura (acciones destructivas) pero omitió aplicar las mismas protecciones a las rutas de lectura equivalentes. Adicionalmente, se identificaron 4 nuevos hallazgos de severidad alta y 6 de severidad media.

SOC-2 Compliance	HIPAA Compliance	CMMC Level 2
45%	**55%**	**40%**
Sin cambio (=)	Sin cambio (=)	Sin cambio (=)

Métrica	Auditoría 1 (12 mar)	Auditoría 2 (13 mar)	Δ
Hallazgos CRITICAL activos	2	3 nuevos identificados	+1
Hallazgos HIGH activos	4	4 (2 nuevos + 2 persistentes)	—
Hallazgos MEDIUM activos	2	6 nuevos	+4
Issues cerrados	0	+0 nuevos cerrados	—
Issues acumulados resueltos	8	8 (sin nuevos cierres)	—

2. Confirmación de Fixes — Auditoría 1

La siguiente tabla verifica que los 8 hallazgos críticos del Audit 1 están correctamente implementados en el codebase actual:

ID (A1)	Descripción	Archivo(s) Afectado(s)	Estado
C-02	IDOR — NinjaOne device *action* routes (reboot/patch/script/services/maintenance)	`api/ninja/devices/[deviceId]/{reboot,patch,script,services,maintenance}/route.ts`	✓ RESUELTO
C-05	IDOR — Search route (acceso cross-tenant sin filtrado)	`api/search/route.ts`	✓ RESUELTO
M-03	IDOR — Custom fields values route (GET + PUT sin tenant check)	`api/custom-fields/values/route.ts`	✓ RESUELTO
M-05	IDOR — Sophos scan/tamper POST routes	`api/sophos/endpoints/[endpointId]/{scan,tamper}/route.ts`	✓ RESUELTO
H-01	HTTP Security Headers ausentes (CSP, HSTS, X-Frame-Options...)	`next.config.ts`	✓ RESUELTO
H-03	RBAC inconsistente — comparación de strings en lugar de `hasMinRole()`	`api/ninja/devices/[deviceId]/{reboot,patch,script...}/route.ts`	✓ RESUELTO
H-04	Middleware sin validación JWT criptográfica (solo cookie-check)	`middleware.ts, lib/auth.config.ts`	✓ RESUELTO
M-06	Secrets hardcodeados / integración Vaultwarden	`Vercel env vars (prod) / .env.local (dev)`	✓ CERRADO

Issues Pendientes del Audit 1 (sin cambios)

Descripción	Estado
Rate limiting en 13+ endpoints críticos	⚠ PENDIENTE
RBAC en mutations: `cross-links POST`, `ad/sync POST`, `ad/groups/*/members POST/DELETE`, `ad/users/[sam] POST` — solo verifican autenticación, no rol	⚠ PENDIENTE

3. Nuevos Hallazgos — Auditoría 2

🔴 CRITICAL

CRITICAL **[NC-01] IDOR — NinjaOne Device GET Routes (7 rutas)** NUEVO

Archivos:

`api/ninja/devices/[deviceId]/route.ts`

`api/ninja/devices/[deviceId]/alerts/route.ts`

`api/ninja/devices/[deviceId]/hardware/route.ts`

`api/ninja/devices/[deviceId]/software/route.ts`

`api/ninja/devices/[deviceId]/patches/route.ts`

`api/ninja/devices/[deviceId]/services/route.ts`

`api/ninja/devices/[deviceId]/assignment/route.ts`

Descripción: Las 7 rutas GET verifican sesión pero **no llaman** `getTenantIdForNinjaDevice()` **ni** `requireTenantAccess()`. El Audit 1 corrigió las rutas de acción (reboot, patch, script...) pero las rutas de *lectura* equivalentes quedaron sin protección. Un usuario de Tenant A puede leer datos de hardware, software, alertas y parches de dispositivos de cualquier otro tenant.

Patrón de ataque: El atacante conoce o enumera un `deviceId` de otro tenant → llama `GET /api/ninja/devices/{id}/hardware` → obtiene inventario completo de hardware (CPU, RAM, discos, modelo) sin autorización.

Fix recomendado:

```
// Agregar al inicio de cada handler GET:
const tenantId = await getTenantIdForNinjaDevice(Number(deviceId));
if (tenantId === null) return NextResponse.json({ error: "Not found" }, { status: 404 });
const deny = await requireTenantAccess(tenantId);
if (deny) return deny;
```

Criterios OWASP/SOC2: A01:2021 Broken Access Control · CC6.6

CRITICAL **[NC-02] IDOR — Sophos Endpoint GET Route** NUEVO

Archivo: `api/sophos/endpoints/[endpointId]/route.ts`

Descripción: El handler GET acepta `tenantId` como query param pero **no llama** `requireTenantAccess(tenantId)`. El Audit 1 corrigió el POST de `scan` y `tamper` pero no el GET del endpoint en sí. Un VIEWER de Tenant A puede leer datos de endpoints de cualquier tenant pasando `?tenantId=X`.

Asimetría detectada: `POST /sophos/endpoints/{id}/scan` → ✓ **PROTEGIDO** · `GET /sophos/endpoints/{id}` → ✗ **EXPUESTO**

Fix recomendado:

```
const deny = await requireTenantAccess(tenantId);
if (deny) return deny;
```

Criterios OWASP/SOC2: A01:2021 Broken Access Control · CC6.6

CRITICAL **[NC-03] Validación insuficiente en operaciones AD — Riesgo Command Injection** NUEVO

Archivo: `api/tenants/[id]/ad/users/[sam]/route.ts` (líneas 55–116)

Descripción: El parámetro `sam` del URL se usa directamente en `psDisableUser(sam)`, `psResetPassword(sam, password)`, etc. Si bien `escapePsParam()` escapa comillas simples, no hay validación del formato SAM (máx 20 chars, alfanumérico). El campo `password` en reset-password tampoco valida complejidad mínima.

```
// SAM sin validación — payload malicioso posible:
const sam = "'; Invoke-Command -ScriptBlock { ... }; $x = '";
const script = psDisableUser(sam); // potencial inyección dependiendo del contexto del agente
```

Fix recomendado:

```
const SAM_REGEX = /^[a-zA-Z0-9_\-\.]{1,20}$/;
if (!SAM_REGEX.test(sam)) {
  return NextResponse.json({ error: "Invalid SAM account name" }, { status: 400 });
}
```

Criterios OWASP: A03:2021 Injection · CWE-78

🟠 HIGH

HIGH **[NH-01] Rate Limiting ausente en todas las rutas API** PERSISTENTE

Alcance: 75+ rutas bajo `src/app/api/`

Descripción: Sin ninguna implementación de rate limiting (Upstash, next-rate-limit, o custom). Permite enumeración de IDs de tenant/dispositivo y DoS en operaciones costosas (Graph API, Sophos API, AD sync). Especialmente crítico en:

- `POST /api/tenants/[id]/ad/users/[sam]` (reset-password — brute-force sin límite)
- `GET /api/ninja/devices/[deviceId]/...` (enumeración de device IDs)
- `POST /api/sophos/endpoints/[id]/scan` (trigger de scans masivos)

Identificado en Audit 1: Sí (sin ID asignado) · **Resuelto:** No

HIGH **[NH-02] Sophos: asimetría GET (sin protección) vs POST (con protección)** NUEVO

Archivo: `api/sophos/endpoints/[endpointId]/scan/route.ts` y `api/sophos/endpoints/[endpointId]/route.ts`

Descripción: El POST de scan incluye correctamente `requireTenantAccess(tenantId)`, pero el GET del endpoint base no lo tiene. Esta asimetría crea una falsa sensación de seguridad — un atacante no puede disparar scans, pero sí leer el estado completo del endpoint (ver NC-02).

HIGH **[NH-03] Audit logging fire-and-forget — Pérdida silenciosa de eventos** PERSISTENTE

Archivo: `src/lib/audit.ts` (líneas 16–27)

Descripción: La función `logAudit()` usa patrón fire-and-forget:

```
prisma.auditLog.create({...}).catch(() => { /* silencioso */ });
```

Fallos en la base de datos (conexión perdida, constraint error) se ignoran silenciosamente. Eventos críticos (resets de contraseña, reboots de dispositivos, modificaciones AD) pueden no quedar registrados — violación directa de SOC-2 CC4.1, CC7.2 e HIPAA §164.312(b).

HIGH **[NH-04] Script parameters sin validación de claves/valores** NUEVO

Archivo: `api/ninja/devices/[deviceId]/script/route.ts` (líneas 36–41)

Descripción: El endpoint acepta `parameters: Record<string, string>` sin validar nombres de claves, longitud de valores ni cantidad de parámetros. Aumenta la superficie de ataque en la ejecución de scripts remotos vía NinjaOne.

🟡 MEDIUM

ID	Archivo	Descripción	Estado
NM-01	`api/bookmarks/route.ts` `api/ninja/devices/route.ts`	Sin límite máximo en `pageSize`/`limit` — queries ilimitadas posibles	NUEVO
NM-02	`next.config.ts, lib/auth.ts`	Sin configuración explícita de `sameSite` en cookies de sesión — sin CSRF tokens explícitos	NUEVO
NM-03	Múltiples rutas API	Error messages exponen detalles internos de Graph API al cliente (tenant GUIDs, mensajes de Azure)	NUEVO
NM-04	`api/tenants/[id]/ad/users/route.ts`	Query param `search` sin límite de longitud (Prisma protege contra SQLi, pero no contra strings de 10MB)	NUEVO
NM-05	`api/ninja/devices/[deviceId]/maintenance/route.ts`	Sin límite máximo de duración de ventana de mantenimiento — se puede fijar indefinidamente (ej. 100 años), deshabilitando alertas y parches	NUEVO
NM-06	`src/lib/sentinel-agent.ts`	Timeout de 30s en scripts PowerShell — insuficiente para dominios AD grandes (>10,000 usuarios)	NUEVO

4. Tabla Maestra Comparativa

ID	Descripción	Audit 1 (12 mar)	Audit 2 (13 mar)
C-02 (A1)	NinjaOne device *actions* IDOR	CRÍTICO	✓ RESUELTO
C-05 (A1)	Search route cross-tenant	CRÍTICO	✓ RESUELTO
M-03 (A1)	Custom fields IDOR	MEDIO	✓ RESUELTO
M-05 (A1)	Sophos scan/tamper IDOR	MEDIO	✓ RESUELTO
H-01 (A1)	HTTP Security Headers ausentes	ALTO	✓ RESUELTO
H-03 (A1)	RBAC string comparison	ALTO	✓ RESUELTO
H-04 (A1)	Middleware JWT validation	ALTO	✓ RESUELTO
M-06 (A1)	Secrets management	MEDIO	✓ CERRADO
— (A1)	Rate limiting (13+ endpoints)	⚠ PENDIENTE	⚠ NH-01 PENDIENTE
— (A1)	RBAC en mutations AD / cross-links	⚠ PENDIENTE	⚠ PENDIENTE
NC-01 (A2)	NinjaOne device *reads* IDOR (7 rutas)	*No auditado*	🔴 NUEVO CRÍTICO
NC-02 (A2)	Sophos endpoint GET IDOR	*No auditado*	🔴 NUEVO CRÍTICO
NC-03 (A2)	AD SAM validation / command injection	*No auditado*	🔴 NUEVO CRÍTICO
NH-02 (A2)	Sophos GET/POST asimetría	*No auditado*	🟠 NUEVO ALTO
NH-03 (A2)	Audit logging fire-and-forget	*No auditado*	🟠 NUEVO ALTO
NH-04 (A2)	Script parameters sin validar	*No auditado*	🟠 NUEVO ALTO
NM-01–06 (A2)	Issues medios varios (paginación, CSRF, info disclosure, SAM length, maintenance, timeout)	*No auditado*	🟡 6 NUEVOS MEDIOS

5. Plan de Acción Priorizado

Acción Inmediata — CRITICAL (antes del próximo deploy)

#	Tarea	Esfuerzo estimado	ID
1	Agregar `getTenantIdForNinjaDevice() + requireTenantAccess()` a las 7 rutas GET de NinjaOne	~30 min	NC-01
2	Agregar `requireTenantAccess(tenantId)` al GET de `sophos/endpoints/[endpointId]`	~5 min	NC-02
3	Validar formato SAM con regex antes de llamadas PowerShell	~15 min	NC-03

Corto plazo — HIGH

#	Tarea	Esfuerzo estimado	ID
4	Implementar rate limiting con `@upstash/ratelimit` en rutas críticas (auth, AD ops, device actions)	~2–4 horas	NH-01
5	Agregar RBAC (role check) a mutations pendientes: `cross-links POST`, `ad/sync POST`, `ad/groups/*/members`	~1 hora	A1 pendiente
6	Envolver `logAudit()` en try/catch con logging a stderr + alerting	~1 hora	NH-03
7	Validar y sanear `parameters` en el route de ejecución de scripts	~30 min	NH-04

6. Mapa de Compliance

Framework	Criterio	Issues Relacionados	Estado
SOC-2	CC6.6 — Logical access restrictions	NC-01, NC-02, NH-01 (pendientes A1)	⚠ INCOMPLETO
SOC-2	CC4.1, CC7.2 — Audit trail / monitoring	NH-03	⚠ INCOMPLETO
SOC-2	CC6.1 — Security headers / secrets	H-01 ✓, M-06 ✓	✓ CUMPLIDO
HIPAA	§164.312(a)(1) — Access control	NC-01, NC-02	⚠ INCOMPLETO
HIPAA	§164.312(b) — Audit controls	NH-03	⚠ INCOMPLETO
CMMC L2	AC.1.002 — Authorized access	NC-01, NC-02, NC-03	⚠ INCOMPLETO
OWASP Top 10	A01:2021 — Broken Access Control	NC-01, NC-02	⚠ CRÍTICO
OWASP Top 10	A03:2021 — Injection	NC-03	⚠ CRÍTICO